

EMPLOYEE DOCUMENT VAULT

Security Hardening & Audit Evidence Report

IAM least privilege, AWS security verification, API authorization and functional validation

PREPARED FOR

Mentor review

TEAM

Nikita

PRIMARY CHANGE

IAM least-privilege hardening

EVIDENCE SET

38-page AWS proof + additional detailed screenshots

Executive Summary

This report presents the Employee Document Vault security review as a mentor-ready case study. It separates the documented IAM hardening change from controls that were already in a secure state and therefore required verification rather than a fabricated before/after state.

2

IAM PERMISSIONS REMOVED

1

AUDIT-LOG PERMISSION RETAINED

4

PROTECTED BUSINESS METHODS

4

LAMBDA TESTS EVIDENCED

IAM

Hardened

CHANGED

Removed s3:ListBucket and dynamodb:Query.

AUDIT LOGGING

Retained

REQUIRED

AuditLogAccess remains in the final policy for audit-trail writing and review.

S3

Already hardened

VERIFIED

Block Public Access and default encryption verified.

DYNAMODB

Already hardened

VERIFIED

Encryption at rest verified with AWS-owned key.

API + COGNITO

Already hardened

VERIFIED

Protected methods use EmployeeVaultCognito; OPTIONS is shown separately.

TRUSTED ADVISOR

Reviewed

NO ACTION

0 action recommended, 0 investigation recommended, 0 excluded-item checks.

Final security position: the IAM policy has a measurable before/after delta, AuditLogAccess is intentionally retained as a required audit capability, and the remaining controls are backed by verification evidence.

Report Contents

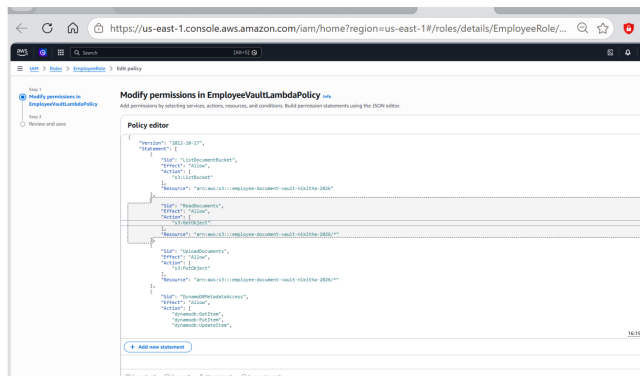
1. IAM baseline and before/after comparison	2. Audit logging and final IAM policy
3. Lambda permission and runtime validation	4. S3 security verification
5. DynamoDB encryption verification	6. API Gateway and Cognito verification
7. Lambda functional validation	8. Trusted Advisor review
9. IAM trust relationship	10. Final audit status and closure
Appendix A. Before policy JSON	Appendix B. After policy JSON
Appendix C. Evidence image register	

Evidence principle: a control already in a secure state is labelled **Already Hardened / Verified**; no artificial "AFTER" screenshot is created.

1. IAM Baseline & Before / After Comparison

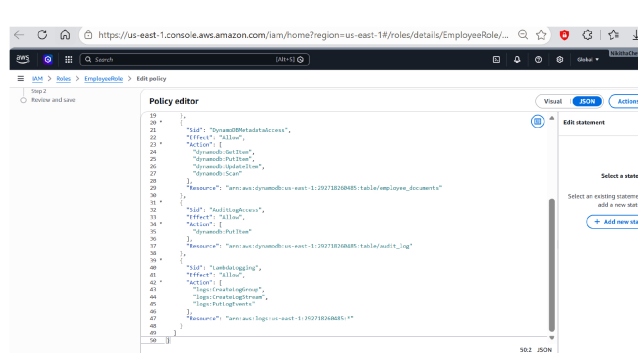
The IAM role under review is **EmployeeRole** with inline policy **EmployeeVaultLambdaPolicy**. The baseline includes S3 bucket-level ListBucket access and DynamoDB Query in addition to object, item, audit-log and CloudWatch permissions.

BEFORE - broader permission set



Baseline evidence visibly includes **s3:ListBucket** and the DynamoDB permission set that included **dynamodb:Query**.

AFTER - least-privilege policy



Final evidence shows the reduced DynamoDB statement and the retained **AuditLogAccess** and CloudWatch logging statements.

Permission delta

Permission	Before	After	Security meaning
s3:ListBucket	Present	Removed	Bucket enumeration capability removed.
s3:GetObject	Present	Present	Retained for document reads/downloads.
s3:PutObject	Present	Present	Retained for uploads.
dynamodb:GetItem	Present	Present	Retained.
dynamodb:PutItem	Present	Present	Retained.
dynamodb:UpdateItem	Present	Present	Retained.
dynamodb:Query	Present	Removed	Unused by the reviewed application implementation.
dynamodb:Scan	Present	Present	Retained in the final policy.
audit_log:dynamodb:PutItem	Present	Retained	Required audit-log capability for later review.
CloudWatch Logs	Present	Present	Retained for Lambda logging.

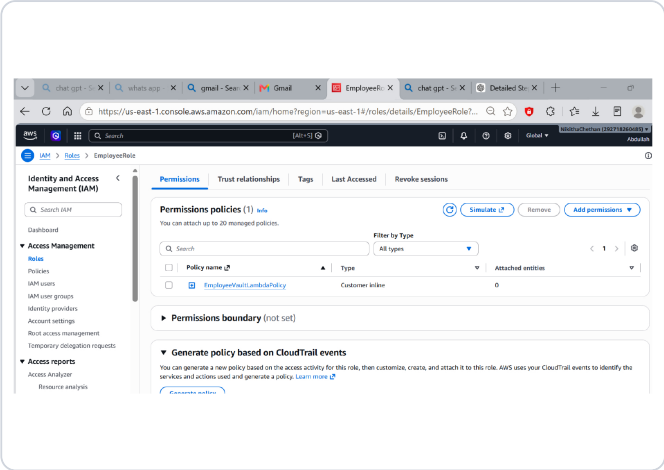


Figure 1 - EmployeeRole baseline - Role and attached policy.

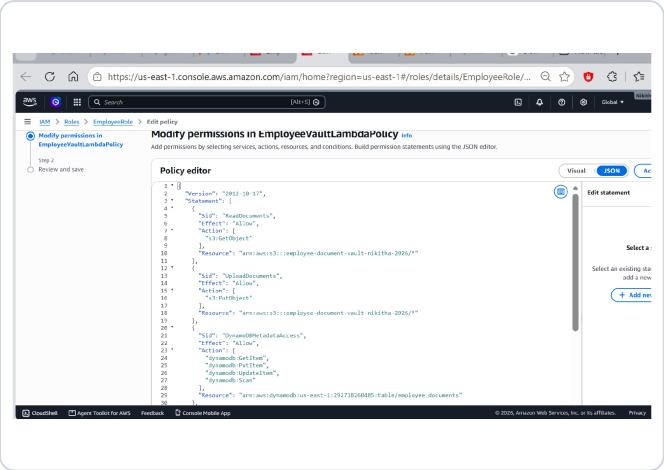


Figure 2 - Final core permissions - Reduced S3/DynamoDB access.

2. Audit Logging & Final IAM Policy

AuditLogAccess is intentionally retained. Audit logging is a required security capability in the final design because the audit trail is used for later review. It is therefore not treated as a pending exception.

Figure 3 - AuditLogAccess in the final policy

Figure 3 - AuditLogAccess in the final policy - dynamodb:PutItem on the dedicated audit_log table remains alongside application and CloudWatch permissions.

Control	Final decision	Audit rationale
AuditLogAccess	Retain	Supports writing security/audit records for later review.
Resource scope	Scoped	Targeted to the dedicated audit_log DynamoDB table.
Lambda logging	Retain	CloudWatch logging permissions remain available for operational evidence.

The final artifact is **09_IAM_AFTER_EmployeeRole.json**. The full JSON is reproduced in Appendix B and is also delivered separately.

3. Lambda Permission & Runtime Validation

The four application functions reviewed are **listDocuments**, **uploadDocument**, **downloadDocument** and **deleteDocument**. The evidence package contains both configuration views and execution results.

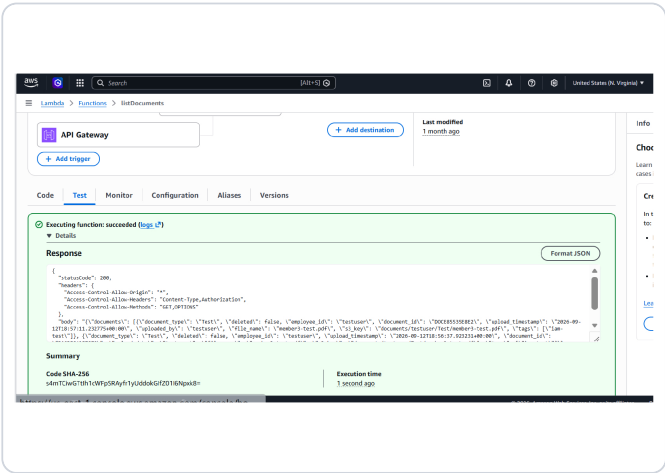


Figure 4 - listDocuments success - 200 response and successful execution.

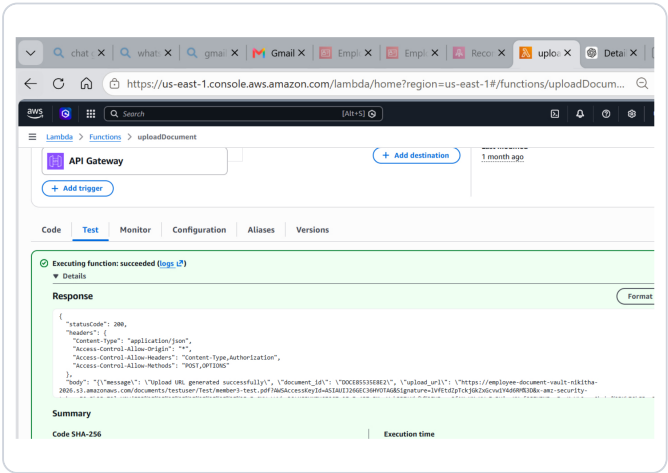


Figure 5 - uploadDocument success - 200 response and successful upload workflow response.

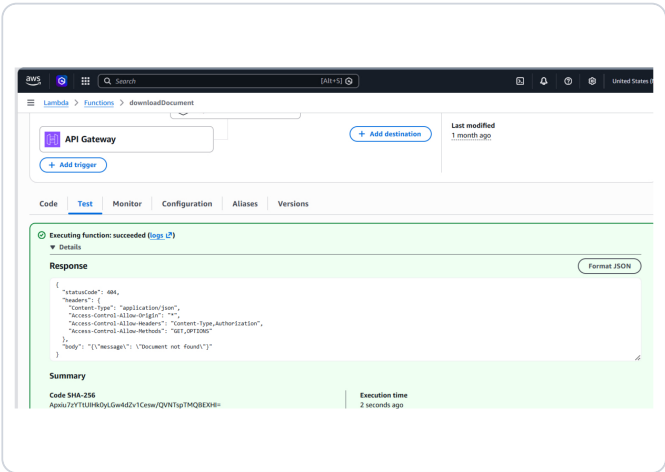


Figure 6 - downloadDocument controlled 404 - Function executes successfully and returns Document not found.

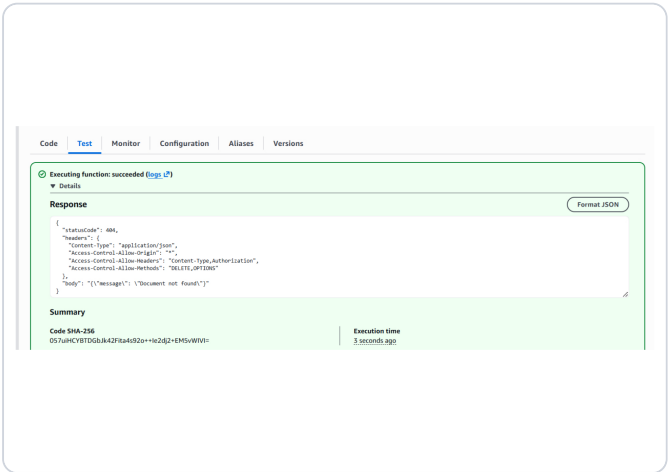


Figure 7 - deleteDocument controlled 404 - Function executes successfully and returns a controlled missing-document response.

Test interpretation: the 404 results are application-level negative-path results, not Lambda execution failures. The console shows successful execution while the function returns the expected missing-document status.

4. S3 Security Verification

ALREADY HARDENED / VERIFIED

No configuration change was required. The captured console evidence demonstrates an already secure state.

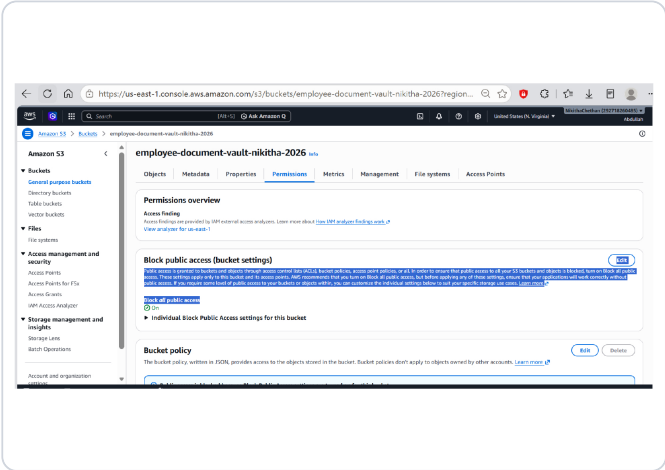


Figure 8 - Block Public Access - Block Public Access enabled; bucket policy view is empty.

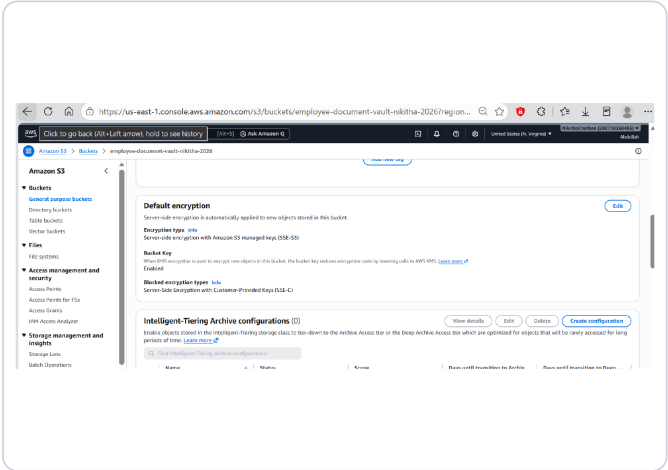


Figure 9 - Default encryption - SSE-S3 is enabled.

Control	Observed state	Assessment
Block Public Access	ON	Verified
Bucket policy	No bucket policy configured	Verified
Default encryption	SSE-S3	Verified

5. DynamoDB Security Verification

ALREADY HARDENED / VERIFIED

The **employee_documents** table already had encryption at rest enabled, so no encryption change was necessary.

Figure 10 - DynamoDB encryption at rest

Figure 10 - DynamoDB encryption at rest - Encryption enabled using AWS-owned key management.

Control	Observed state	Assessment
Encryption at rest	Enabled	Verified
Key management	AWS owned key	Verified

6. API Gateway + Cognito Verification

ALREADY HARDENED / VERIFIED

The API protection layer is already configured. The evidence demonstrates protected business methods and separately shows the unauthenticated OPTIONS paths used for the API's CORS handling.

Endpoint	Method	Authorization	Result
/download/{doc_id}	GET	EmployeeVaultCognito	Protected
/files	GET	EmployeeVaultCognito	Protected
/files/{doc_id}	DELETE	EmployeeVaultCognito	Protected
/upload	POST	EmployeeVaultCognito	Protected
CORS paths	OPTIONS	NONE	Preflight path

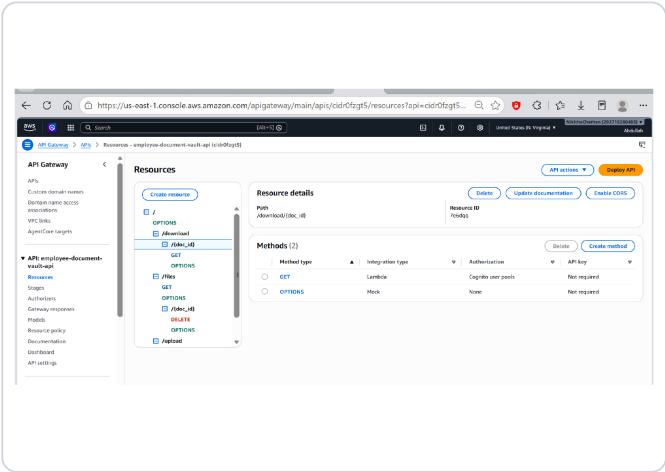


Figure 11 - API resource and method inventory - The resource tree shows download, files, delete and upload paths.

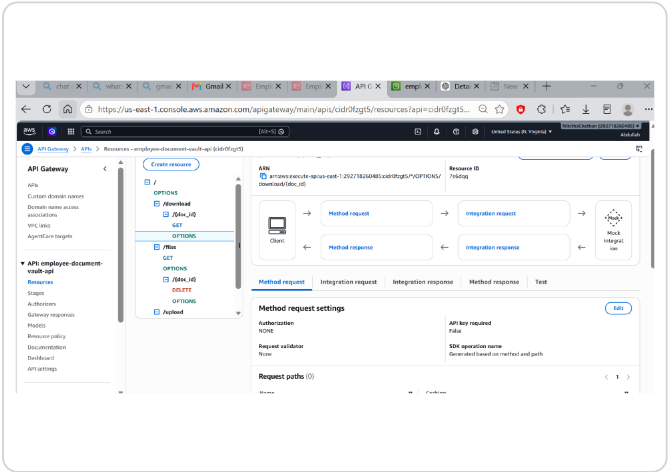


Figure 12 - Protected GET method - GET method request is configured with EmployeeVaultCognito.

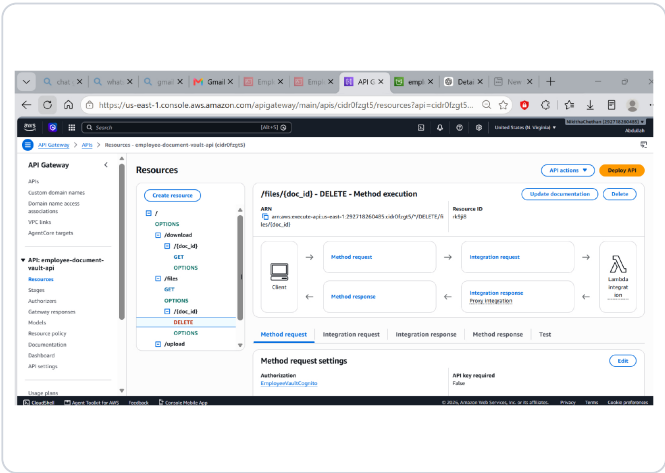


Figure 13 - Protected DELETE method - DELETE /files/{doc_id} uses EmployeeVaultCognito.

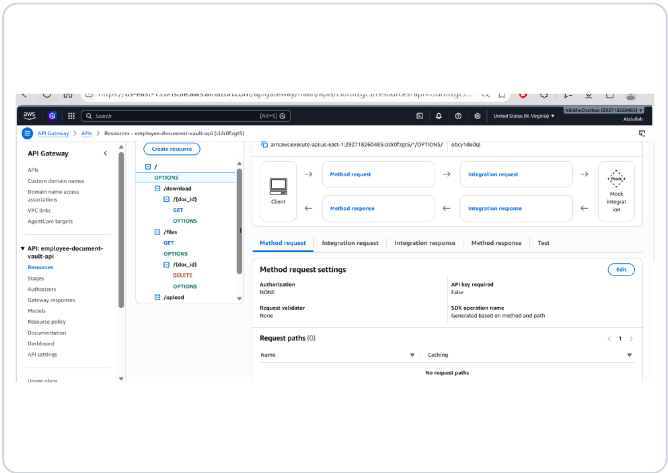


Figure 14 - Upload method - POST /upload is part of the protected business-method surface.

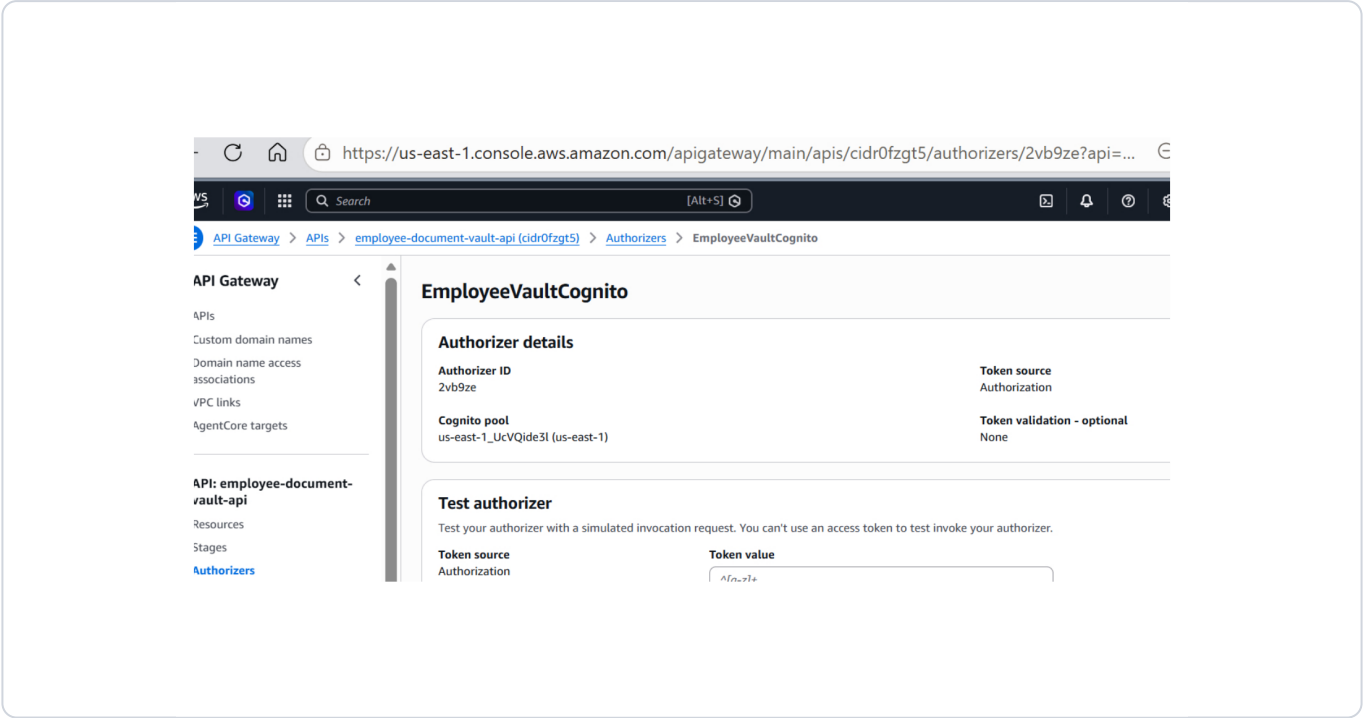


Figure 15 - EmployeeVaultCognito authorizer - Authorization is the token source and the configured Cognito user pool is visible.

OPTIONS distinction: the captured screenshots show Authorization = NONE on OPTIONS methods. The business methods above are separately configured with the Cognito authorizer.

Additional detailed API screenshots

The extra screenshots supplied outside the original 38-page proof set are retained as separate evidence and summarized here so the review is not dependent on a single generic API page.

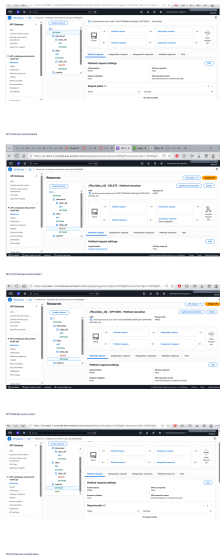


Figure 16 - Detailed API authorization evidence montage - Additional supplied method-level screenshots.

7. Lambda Functional Validation

Testing evidence demonstrates both positive-path application behavior and controlled negative-path responses after the security work.

LISTDOCUMENTS

HTTP 200

Successful document-list response.

UPLOADDOCUMENT

HTTP 200

Successful upload workflow response.

DOWNLOAD + DELETE

HTTP 404

Controlled missing-document behavior.

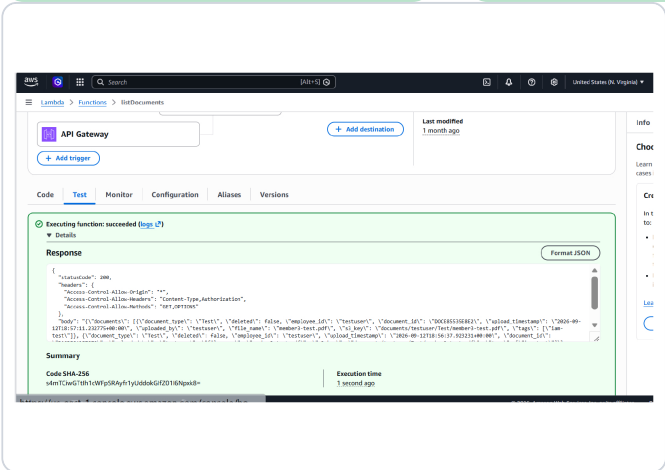


Figure 17 - listDocuments test - Successful execution, HTTP 200.

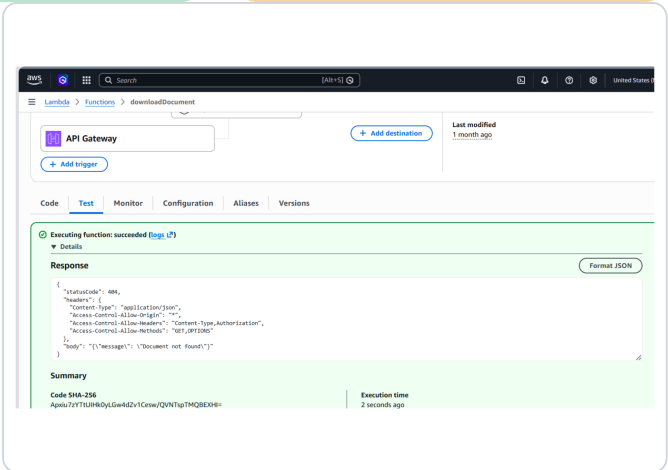


Figure 18 - downloadDocument test - Successful execution with controlled 404.

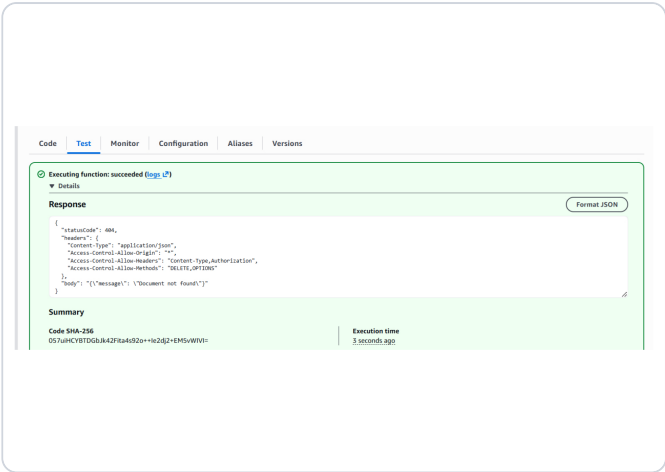


Figure 19 - deleteDocument test - Successful execution with controlled 404.

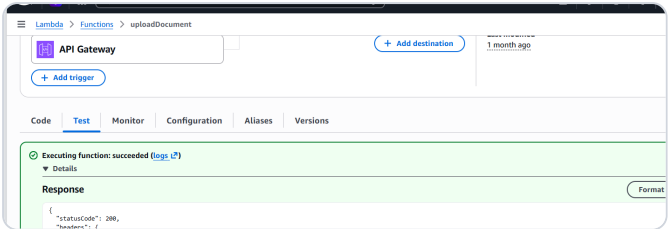


Figure 20 - uploadDocument test - Sanitized screenshot showing success without exposing the long upload URL query string.

Validation result: the available evidence shows the Lambda functions executing successfully and returning expected application-level responses.

8. Trusted Advisor Review

REVIEWED / NO ACTION SHOWN

The captured recommendation view shows 0 action recommended, 0 investigation recommended and 0 excluded-item checks. The page also notes that full Trusted Advisor checks depend on the support plan.

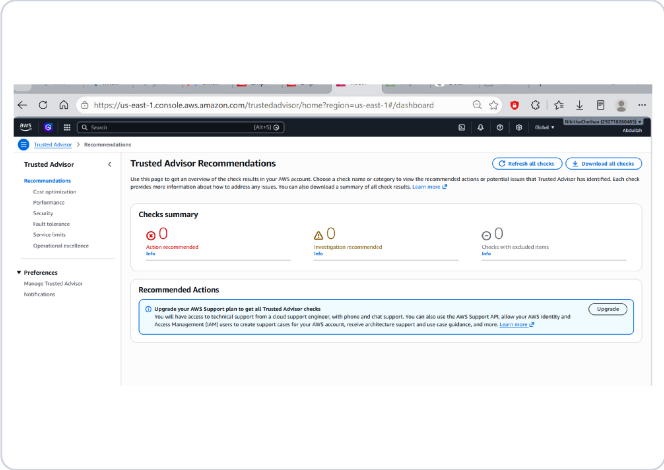


Figure 21 - Trusted Advisor summary - 0 / 0 / 0 across the displayed check categories.

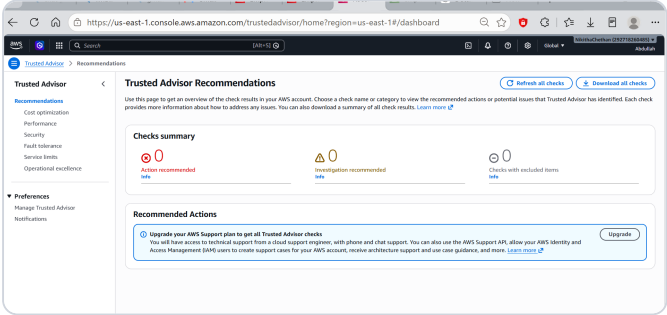


Figure 22 - Detailed Trusted Advisor evidence - Additional supplied Trusted Advisor screenshot.

9. IAM Trust Relationship

The execution role trust policy permits the Lambda service principal to assume **EmployeeRole**. This is supporting configuration evidence and is separate from the permission-policy hardening delta.

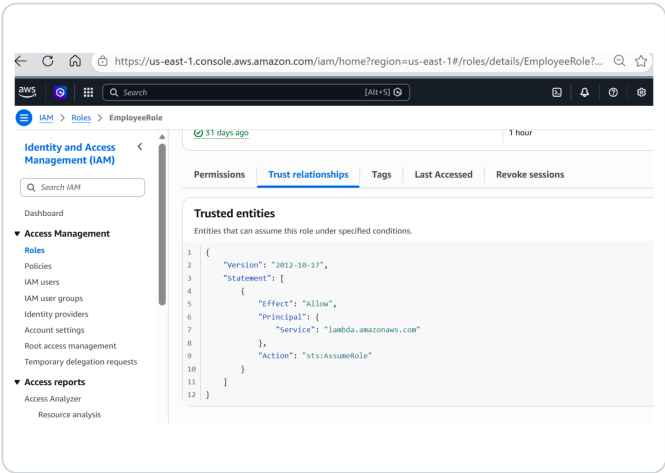


Figure 23 - EmployeeRole trust relationship - Lambda service principal and sts:AssumeRole are visible.

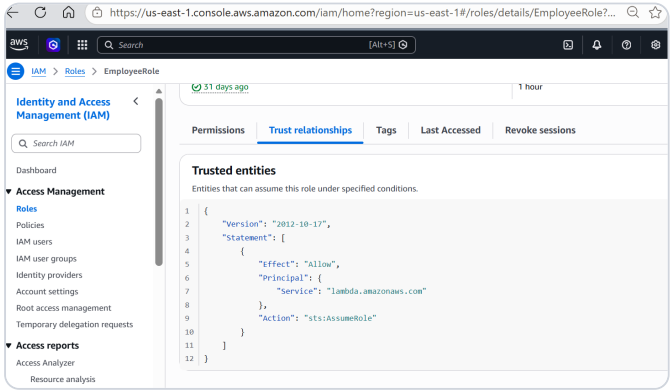


Figure 24 - Detailed trust relationship evidence - Additional supplied trust-policy screenshot.

10. Final Audit Status & Closure

Control area	Final status	Audit conclusion
IAM least privilege	Hardened	Removed s3:ListBucket and dynamodb:Query.
Audit logging	Required / retained	AuditLogAccess intentionally remains for audit-log writes and later review.
S3 security	Verified	Block Public Access, no bucket policy and SSE-S3 verified.
DynamoDB encryption	Verified	Encryption at rest enabled with AWS-owned key.
API Gateway / Cognito	Verified	Business methods use EmployeeVaultCognito; OPTIONS shown separately.
Lambda validation	Tested	200 success and controlled 404 evidence captured.
Trusted Advisor	Reviewed	0 action recommended, 0 investigation recommended, 0 excluded-item checks shown.
IAM trust relationship	Verified	Lambda service principal can assume EmployeeRole.

Submission checklist

- **08_IAM_BEFORE_EmployeeRole.json** - original policy baseline.
- **09_IAM_AFTER_EmployeeRole.json** - final hardened policy with AuditLogAccess retained.
- **10_IAM_Before_After_Comparison.docx** - detailed IAM comparison document.
- **Employee_Document_Vault_Security_Hardening_Case_Study_FINAL.pdf** - mentor-ready case study.
- Descriptively named evidence screenshots - preserved separately.

Audit-ready conclusion: unnecessary IAM permissions were removed, audit logging was deliberately preserved, existing hardened controls are verified with evidence, and the application was exercised with positive and controlled negative test cases.

Appendix A - BEFORE Policy JSON

Artifact: 08_IAM_BEFORE_EmployeeRole.json

```
{
  "Version": "2012-10-17",
  "Statement": [
    {
      "Sid": "ListDocumentBucket",
      "Effect": "Allow",
      "Action": [
        "s3:ListBucket"
      ],
      "Resource": "arn:aws:s3:::employee-document-vault-nikitha-2026"
    },
    {
      "Sid": "ReadDocuments",
      "Effect": "Allow",
      "Action": [
        "s3:GetObject"
      ],
      "Resource": "arn:aws:s3:::employee-document-vault-nikitha-2026/*"
    },
    {
      "Sid": "UploadDocuments",
      "Effect": "Allow",
      "Action": [
        "s3:PutObject"
      ],
      "Resource": "arn:aws:s3:::employee-document-vault-nikitha-2026/*"
    },
    {
      "Sid": "DynamoDBMetadataAccess",
      "Effect": "Allow",
      "Action": [
        "dynamodb:GetItem",
        "dynamodb:PutItem",
        "dynamodb:UpdateItem",
        "dynamodb:Query",
        "dynamodb:Scan"
      ],
      "Resource": "arn:aws:dynamodb:us-east-1:292718260485:table/employee_documents"
    },
    {
      "Sid": "AuditLogAccess",
      "Effect": "Allow",
      "Action": [
        "dynamodb:PutItem"
      ],
      "Resource": "arn:aws:dynamodb:us-east-1:292718260485:table/audit_log"
    },
    {
      "Sid": "LambdaLogging",
      "Effect": "Allow",
      "Action": [
        "logs:CreateLogGroup",
        "logs:CreateLogStream",
        "logs:PutLogEvents"
      ],
      "Resource": "arn:aws:logs:us-east-1:292718260485:*"
    }
  ]
}
```

Appendix B - AFTER Policy JSON

Artifact: 09_IAM_AFTER_EmployeeRole.json

```
{
  "Version": "2012-10-17",
  "Statement": [
    {
      "Sid": "ReadDocuments",
      "Effect": "Allow",
      "Action": [
        "s3:GetObject"
      ],
      "Resource": "arn:aws:s3:::employee-document-vault-nikitha-2026/*"
    },
    {
      "Sid": "UploadDocuments",
      "Effect": "Allow",
      "Action": [
        "s3:PutObject"
      ],
      "Resource": "arn:aws:s3:::employee-document-vault-nikitha-2026/*"
    },
    {
      "Sid": "DynamoDBMetadataAccess",
      "Effect": "Allow",
      "Action": [
        "dynamodb:GetItem",
        "dynamodb:PutItem",
        "dynamodb:UpdateItem",
        "dynamodb:Scan"
      ],
      "Resource": "arn:aws:dynamodb:us-east-1:292718260485:table/employee_documents"
    },
    {
      "Sid": "AuditLogAccess",
      "Effect": "Allow",
      "Action": [
        "dynamodb:PutItem"
      ],
      "Resource": "arn:aws:dynamodb:us-east-1:292718260485:table/audit_log"
    },
    {
      "Sid": "LambdaLogging",
      "Effect": "Allow",
      "Action": [
        "logs:CreateLogGroup",
        "logs:CreateLogStream",
        "logs:PutLogEvents"
      ],
      "Resource": "arn:aws:logs:us-east-1:292718260485:*"
    }
  ]
}
```

Appendix C - Evidence Image Register

All screenshots are named by security function so they can be reused in the mentor submission, audit folder or presentation without ambiguous raw filenames.

Evidence file	Description
01_IAM_ROLE_BEFORE.png	IAM role baseline - EmployeeRole and attached policy
02_IAM_POLICY_BEFORE_S3_DDB.png	IAM BEFORE policy - S3 ListBucket, object permissions and DynamoDB Query
03_IAM_POLICY_AFTER_AUDIT_LOG.png	IAM AFTER policy - AuditLogAccess, employee_documents access and CloudWatch logging
04_IAM_POLICY_AFTER_CORE.png	IAM AFTER policy - retained core S3 and DynamoDB permissions
05_S3_PUBLIC_ACCESS_VERIFIED.png	S3 - Block Public Access verification
06_S3_ENCRYPTION_VERIFIED.png	S3 - default encryption verification
07_DYNAMODB_ENCRYPTION_VERIFIED.png	DynamoDB - encryption at rest verification
08_API_GATEWAY_RESOURCE_METHODS.png	API Gateway - resource and method inventory
09_API_GET_METHOD_AUTHORIZATION.png	API Gateway - protected GET method
10_API_DELETE_METHOD_AUTHORIZATION.png	API Gateway - protected DELETE method
11_API_UPLOAD_METHOD_AUTHORIZATION.png	API Gateway - upload method configuration
12_COGNITO_AUTHORIZER.png	Cognito - EmployeeVaultCognito authorizer
13_TRUSTED_ADVISOR.png	Trusted Advisor - recommendation summary
14_LAMBDA_LIST_SUCCESS.png	Lambda listDocuments - successful 200 test
15_LAMBDA_DOWNLOAD_404.png	Lambda downloadDocument - controlled 404 test
16_LAMBDA_DELETE_404.png	Lambda deleteDocument - controlled 404 test
17_LAMBDA_UPLOAD_SUCCESS.png	Lambda uploadDocument - successful 200 test
18_IAM_TRUST_RELATIONSHIP.png	IAM - Lambda trust relationship
19_API_METHOD_DETAIL_01.png	Detailed API method configuration evidence
20_API_METHOD_DETAIL_02.png	Detailed API method configuration evidence
21_API_RESOURCE_METHODS_DETAIL.png	Detailed API resource/method evidence
22_API_DELETE_DETAIL.png	Detailed DELETE method evidence
23_API_OPTIONS_DETAIL.png	Detailed OPTIONS/CORS evidence
24_API_METHOD_DETAIL_03.png	Detailed API POST/GET method evidence

25_API_METHOD_DETAIL_04.png	Detailed API method evidence
26_COGNITO_AUTHORIZER_DETAIL.png	Detailed Cognito authorizer evidence
27_TRUSTED_ADVISOR_DETAIL.png	Detailed Trusted Advisor evidence
28_LAMBDA_LIST_TEST.png	Lambda listDocuments test screenshot
29_LAMBDA_DOWNLOAD_TEST.png	Lambda downloadDocument test screenshot
30_LAMBDA_UPLOAD_TEST_SUCCESS.png	Sanitized Lambda uploadDocument test screenshot
31_IAM_TRUST_RELATIONSHIP_DETAIL.png	Detailed IAM trust relationship evidence
API_AUTHORIZATION_EVIDENCE_MONTAGE.png	API authorization evidence montage